Vulnerability Assessment Report

AuSecurity - Vulnerability Assessment Report

AuSecurity
63 Paddington St
Paddington NSW 2021, Australia

Flinders University
Sturt Road, Bedford Park SA 5042

September 18, 2026

Report Version: 1.0

CONFIDENTIAL

Table of Contents

List of Figures 4

1 Document Control 5

1.1 Team 5

1.2 List of Changes 5

2 Executive Summary 6

2.1 Overview 6

2.2 Identified Vulnerabilities 7

3 Methodology 9

3.1 Objective 9

3.2 Scope 9

3.3 User Accounts and Permissions 10

4 Findings 11

C1: Unauthenticated osTicket installer exposed 11

M1: Self-signed TLS certificate and hostname mismatch on the main site ... 12

M2: DOM-based cross-site scripting on consultation success page 13

M3: Missing HTTP security headers 14

M4: No MX, SPF, or DMARC for ausecurity.best 15

M5: WordPress XML-RPC enabled with pingback and multicall 16

M6: WordPress administrator username disclosed 17

M7: WordPress directory listing enabled 18

M8: Marketing site and ticket installer served over cleartext HTTP on port 8080 19

M9: HTTPS paths redirect to HTTP 20

I1: Software version information disclosed 21

5 Disclaimer 22

A Appendix 23

A.1 Static Appendix Section 23

A.2 Remediation priority 23
A.3 Finding severity (from verified CVSS vectors) 24
A.4 Business and contact details 24

List of Figures

Figure 1 - Distribution of identified vulnerabilities 8

1 Document Control

1.1 Team

Contact	Details	Role
ClawSec	Autonomous agent	Pentester

1.2 List of Changes

Version	Description	Date
1.0	Initial vulnerability assessment report	Sep 18, 2026

2 Executive Summary

2.1 Overview

Overview

ClawSec completed an owner-authorized vulnerability assessment of AuSecurity on 18 September 2026. AuSecurity is a governance, risk, and compliance (GRC) consulting and penetration testing firm at 63 Paddington St, Paddington NSW 2021, Australia. Testing covered the public website, WordPress blog, ticket system, and the three approved servers that host them.

What we found

The assessment confirmed **11 findings**:

Severity	Count
Critical	1
High	0
Medium	3
Low	6
Informational	1

Issue that needs action first

The public ticket host (`ticket.ausecurity.best`) still shows the osTicket installation wizard to anyone on the internet. A stranger who finishes that setup could choose the administrator account and take control of the future support platform, including customer tickets. Completing the installer was not performed during this test.

Other important issues

The main website has a cross-site scripting flaw on the consultation thank-you page. A crafted link can run an attacker's script in a visitor's browser.

The main site uses a self-signed certificate that browsers do not trust, and the www and contact names are not on that certificate. The same websites are also available without encryption on port 8080, so traffic can be read or changed on the network. The WordPress blog discloses the login name `admin` and lists files in some folders.

What to do first

1. Finish osTicket setup privately, or take the ticket host offline, and remove or lock down `/setup/` immediately.
2. Stop writing the `name` query parameter into the thank-you page with `innerHTML`; use plain text instead.
3. Replace the homemade certificate with a publicly trusted certificate covering `ausecurity.best`, `www.ausecurity.best`, and `contact.ausecurity.best`, and close port 8080 if it is not needed.

Testing we did not claim as a problem

No evidence of SQL injection was found on the contact API. The public dashboard HTML is a static mock and was not reported as broken access control. WordPress plugin CVE lists were not claimed (vulnerability database token missing). SSH was not logged into. Password guessing and other forbidden methods were not used.

2.2 Identified Vulnerabilities

#	CVSS	Description	Page
C1	9.8	Unauthenticated osTicket installer exposed	11
M1	6.8	Self-signed TLS certificate and hostname mismatch on the main site	12
M2	6.1	DOM-based cross-site scripting on consultation success page	13
M3	5.4	Missing HTTP security headers	14
M4	5.3	No MX, SPF, or DMARC for ausecurity.best	15
M5	5.3	WordPress XML-RPC enabled with pingback and multicall	16
M6	5.3	WordPress administrator username disclosed	17
M7	5.3	WordPress directory listing enabled	18
M8	4.8	Marketing site and ticket installer served over cleartext HTTP on port 8080	19
M9	4.2	HTTPS paths redirect to HTTP	20
I1	0.0	Software version information disclosed	21

Vulnerability Overview

In the course of this penetration test **1 Critical**, **9 Medium** and **1 Info** vulnerabilities were identified:

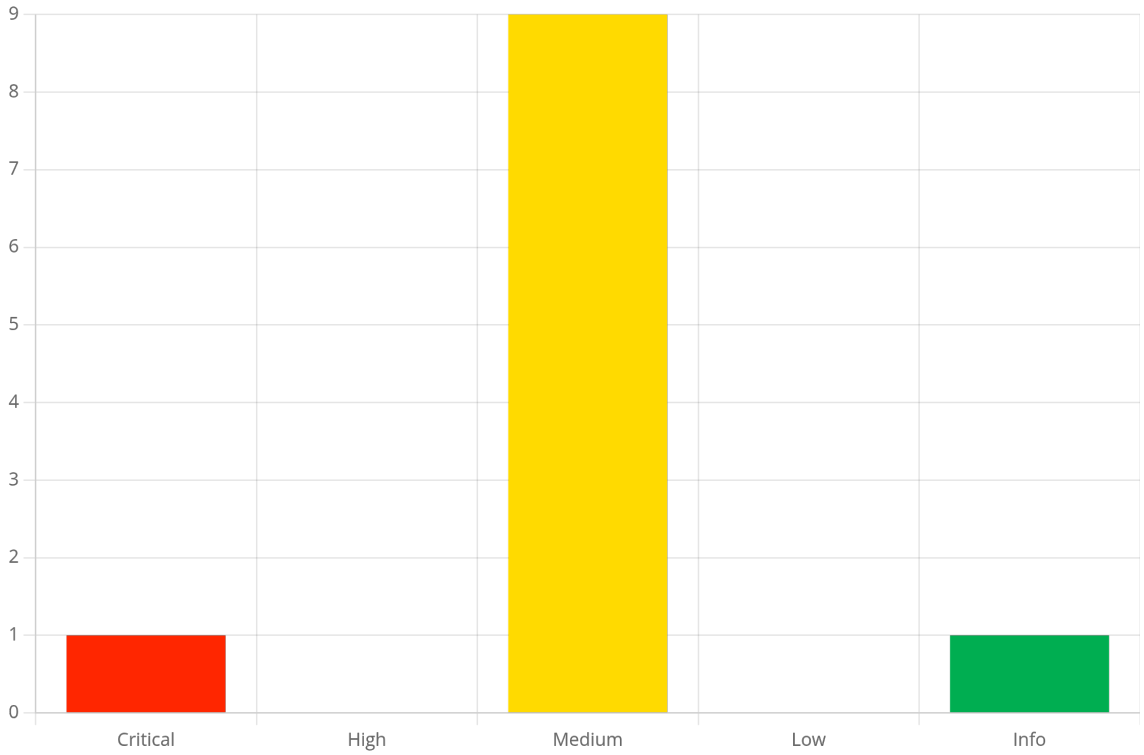


Figure 1 - Distribution of identified vulnerabilities

3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasiable, seamless and cost-affective such approach is.

3.2 Scope

Engagement

Owner-authorized full-scope vulnerability assessment of AuSecurity public internet assets. Intake, authorization, enumeration, assessment, validation, and reporting all occurred on 18 September 2026.

Authorization was confirmed with a GET request to `https://ausecurity.best/` that included the `IsAuthorized` request header; the expected agreement response header matched. The authorization secret was not stored.

In-scope assets (owner-approved)

System	Address	Description
ausecurity.best / www / contact	51.79.166.148	Main marketing site; nginx 1.22.1; extra HTTP nginx 1.25.5 on TCP 8080; OpenSSH 9.2p1
blog.ausecurity.best	51.79.167.208	WordPress 7.1.1, theme hello-elementor 3.0.0, Apache 2.4.68
ticket.ausecurity.best	51.79.166.209	osTicket 1.18.4 uninstalled; nginx 1.22.1 PHP 8.2.33; Apache 2.4.68 on TCP 8080

Domains: ausecurity.best, www.ausecurity.best, blog.ausecurity.best, ticket.ausecurity.best, contact.ausecurity.best

URLs: https://ausecurity.best/, https://www.ausecurity.best/, https://blog.ausecurity.best/, https://ticket.ausecurity.best/, https://contact.ausecurity.best/

IPs: 51.79.166.148, 51.79.167.208, 51.79.166.209

Explicitly out of scope

- OVH ASN AS16276 and netblocks 51.79.164.0/22 and 51.79.128.0/17 except the three IPs above
- Spaceship DNS (launch1/launch2.spaceship.net), Google Fonts, OVH PTR hostnames
- Lookalike domains ausecurity.com.au, ausecurity.net, ausecurity.com

- flinders.edu.au

Methodology

- Fast port discovery (top 200 ports), then version scan on open ports only
- Web mapping from public JavaScript and HTML
- Unauthenticated WordPress enumeration without password attacks
- Safe GET requests to the osTicket installer without completing setup
- Single-request API probes
- Execution delegated to isolated command workers

Not performed

DDoS, malware, phishing, social engineering, credential stuffing, password spraying, brute force, MFA bypass, lateral movement, destructive changes, neighbour-IP scanning, and completing the osTicket installer.

Limitations and coverage

- WPScan vulnerability database not used (API token missing); plugin CVE list not claimed
- amass, SecurityTrails, VirusTotal, and Censys were unavailable
- No authenticated testing of the main-site admin API (no credentials; brute force forbidden)
- Dashboard HTML is a public static mock; not reported as broken access control
- SQL injection not evidenced (contact API accepted quoted input with no database errors)
- XML-RPC pingback SSRF not exploited
- SSH not authenticated
- Self-signed TLS required an insecure-skip-verify client flag to fetch the main site

3.3 User Accounts and Permissions

No user credentials were provided. All testing was unauthenticated. Password guessing and brute force were forbidden and were not performed.

Published contacts used only for report addressing:

- Owner: Vinh Dinh — dinh0087@flinders.edu.au
- Site email: info@ausecurity.best
- Published phone: +61 2 9000 1234 (may be a placeholder)

4 Findings

C1: Unauthenticated osTicket installer exposed	
Score	9.8 (Critical)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Target	• https://ticket.ausecurity.best/ • https://ticket.ausecurity.best/setup/ • https://ticket.ausecurity.best/setup/install.php • http://51.79.166.209:8080/setup/install.php
References	https://docs.osticket.com/en/latest/Getting%20Started/Installation.html

Overview

Anyone on the internet can open the ticket system's installation wizard and finish setup themselves.

Details

ticket.ausecurity.best is an osTicket v1.18.4 instance that has not been installed. Unauthenticated GET requests to /setup/install.php and /setup/ return HTTP 200 and the osTicket prerequisites wizard (PHP/MySQL checks passing, continue form present, PHPSESSID cookie set). Application paths including /scp/login.php, /login.php, /kb/, and /api/http.php all HTTP 302 to /setup/install.php, confirming the product is in pre-install state rather than a leftover file on a live helpdesk. The same installer is also served in cleartext on TCP 8080 (Apache/2.4.68, PHP/8.2.33). Completing the wizard was not performed. If completed by an attacker, they could choose the admin account and database settings and take full control of the future support platform, including customer tickets.

Recommendation

Take the host offline until osTicket is installed privately. Restrict /setup/ to localhost or remove the setup directory after install. Require HTTPS only and close TCP 8080 if it is not needed. Place the helpdesk behind authentication and a firewall allowlist where possible.

M1: Self-signed TLS certificate and hostname mismatch on the main site	
Score	6.8 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N
Target	• https://ausecurity.best/ • https://www.ausecurity.best/ • https://contact.ausecurity.best/ • 51.79.166.148:443
References	-

Overview

The main website uses a homemade certificate that browsers do not trust, and www/contact names are not on the certificate.

Details

openssl against 51.79.166.148 with server name ausecurity.best returned a certificate subject CN=ausecurity.best, issuer CN=ausecurity.best (self-signed), SAN DNS:ausecurity.best only, valid 2026-09-14 to 2027-09-14. www.ausecurity.best and contact.ausecurity.best present the same certificate, so the hostname does not match. Visitors see warnings; a network attacker can more easily intercept or replace the session because there is no public-CA chain to pin trust. blog.ausecurity.best and ticket.ausecurity.best correctly use Let's Encrypt certificates and are not this issue.

Recommendation

Issue a publicly trusted certificate (Let's Encrypt or commercial) covering ausecurity.best, www.ausecurity.best, and contact.ausecurity.best. Redirect all names to the canonical host. Enable HSTS after HTTPS works without warnings.

M2: DOM-based cross-site scripting on consultation success page	
Score	6.1 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Target	• https://ausecurity.best/consultation-success.html • https://www.ausecurity.best/consultation-success.html • https://contact.ausecurity.best/consultation-success.html
References	https://owasp.org/www-community/attacks/DOM_Based_XSS

Overview

A crafted link on the public website can run an attacker's script in a visitor's browser.

Details

consultation-success.html reads the `name` query parameter with URLSearchParams and assigns it to the DOM with innerHTML (element id user-name). The `company` parameter is assigned with textContent and is not this sink. The contact API (POST /api/contact) returns redirect_url=`/consultation-success.html?name=<full_name>&company=<company_name>`, and main.js sets window.location.href to that value. Direct evidence: the page JavaScript contains `document.getElementById('user-name').innerHTML = userName`. A malicious URL such as `/consultation-success.html?name=<img src=x onerror=...>` is sufficient proof; the payload was not driven further. Impact is session/script execution in the site origin for any user who opens the link.

Recommendation

Stop using innerHTML for untrusted URL data. Use textContent (as already done for company). Encode output and add a strict Content-Security-Policy. Validate redirect_url on the client to same-origin paths without embedding raw HTML.

M3: Missing HTTP security headers	
Score	5.4 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Target	• https://ausecurity.best/ • https://www.ausecurity.best/ • https://contact.ausecurity.best/ • https://blog.ausecurity.best/ • https://ticket.ausecurity.best/
References	https://owasp.org/www-project-secure-headers/

Overview

None of the public sites tell browsers to enforce basic protections such as click-jacking defense or HTTPS-only mode.

Details

Response headers on all five HTTPS URLs lacked Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy. Combined with the DOM XSS sink, missing CSP is especially relevant. Missing X-Frame-Options/CSP frame-ancestors allows the pages to be framed.

Recommendation

Add HSTS (after valid public TLS), a restrictive CSP, X-Frame-Options: DENY or CSP frame-ancestors 'none', X-Content-Type-Options: nosniff, and a conservative Referrer-Policy.

M4: No MX, SPF, or DMARC for ausecurity.best	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Target	ausecurity.best (DNS)
References	https://www.dmarc.org/

Overview

The company domain has no mail authentication, so others can more easily send email that looks like it comes from AuSecurity.

Details

Enumeration found no MX, SPF (TXT), or DMARC records for ausecurity.best. The public contact address info@ausecurity.best therefore has no dedicated mail infrastructure or spoofing controls. This does not prove a mailbox is compromised; it does mean receivers have no policy to reject forged @ausecurity.best mail.

Recommendation

If email is used, publish MX plus SPF and a DMARC policy (start with p=quarantine, then p=reject). If email is not used, publish an explicit deny SPF (`v=spf1 -all`) and DMARC reject.

M5: WordPress XML-RPC enabled with pingback and multicall	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L
Target	https://blog.ausecurity.best/xmlrpc.php
References	https://wordpress.org/documentation/article/xml-rpc/

Overview

An old WordPress remote-control interface is turned on, including methods often abused for abuse and password guessing.

Details

xmlrpc.php returns HTTP 200 text/xml. system.listMethods succeeded and included pingback.ping and system.multicall. Password guessing via XML-RPC was not performed (out of method). Pingback SSRF was not exploited. The enabled surface is unnecessary for a simple blog and is a common attack entry point.

Recommendation

Disable XML-RPC if not required (remove xmlrpc.php or block it in Apache). If remote publishing is needed, restrict by IP and disable pingbacks.

M6: WordPress administrator username disclosed	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	• https://blog.ausecurity.best/?author=1 • https://blog.ausecurity.best/index.php/author/admin/
References	-

Overview

The blog reveals that a login name of “admin” exists.

Details

WPScan user enumeration and GET /?author=1 (301 to https://blog.ausecurity.best/index.php/author/admin/) both identified username admin. REST /wp-json/wp/v2/users returned 404 and did not list users. Passwords were not attacked. Knowing a valid username reduces the work needed for a later password attack.

Recommendation

Do not use the username admin. Create a new editor/administrator with a non-guessable login, delete or demote admin, and disable author ID redirects (or return 404).

M7: WordPress directory listing enabled	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	• https://blog.ausecurity.best/wp-content/uploads/ • https://blog.ausecurity.best/wp-includes/
References	-

Overview

The blog web server lists files in folders instead of hiding them.

Details

Apache directory indexes are enabled. GET /wp-content/uploads/ returned a listing containing 2026/. GET /wp-includes/ returned HTTP 200 with a large HTML index of WordPress core files (about 65 KB). This helps an attacker fingerprint the CMS and find uploaded files as they appear. No backup archives were present in uploads at the time of testing.

Recommendation

Turn off Options Indexes for the WordPress vhost. Deny web access to wp-includes listing and keep uploads without directory index.

M8: Marketing site and ticket installer served over cleartext HTTP on port 8080	
Score	4.8 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
Target	• http://51.79.166.148:8080/ • http://51.79.166.209:8080/ • http://51.79.166.209:8080/setup/install.php
References	-

Overview

The same websites are also available without encryption on an extra port, so traffic can be read or changed on the network.

Details

nmap showed TCP 8080 open on 51.79.166.148 (nginx 1.25.5) and 51.79.166.209 (Apache 2.4.68). GET http://51.79.166.148:8080/ with Host ausecurity.best returned HTTP 200 and the full corporate homepage (same ETag/body length as port 443) with no redirect to HTTPS. GET http://51.79.166.209:8080/ returned 302 to /setup/install.php and the osTicket installer over HTTP. Port 80 on the main site correctly 301s to HTTPS; port 8080 does not. This exposes page content and the installer to passive interception.

Recommendation

Disable port 8080 or bind it to localhost. If a second HTTP listener is required, force a 301 to HTTPS and do not serve the installer in cleartext.

M9: HTTPS paths redirect to HTTP	
Score	4.2 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N
Target	• https://ausecurity.best/api • https://ausecurity.best/assets
References	-

Overview

Some secure URLs send the browser to an insecure http:// address.

Details

GET https://ausecurity.best/api returned 301 Location: http://ausecurity.best/api/. GET https://ausecurity.best/assets returned 301 Location: http://ausecurity.best/assets/. This is the common nginx trailing-slash redirect using an http scheme, which can downgrade a user from HTTPS to HTTP (then port 80 does redirect back to HTTPS, but the first hop is cleartext). /assets/ itself returns 403.

Recommendation

Set nginx absolute_redirect/server_name_in_redirect so trailing-slash redirects stay on https://. Add HSTS after the certificate is trusted.

I1: Software version information disclosed	
Score	0.0 (Info)
Vector string	N/A
Target	• https://ausecurity.best/ • 51.79.166.148 • https://blog.ausecurity.best/ • 51.79.167.208 • https://ticket.ausecurity.best/ • 51.79.166.209
References	-

Overview

Servers advertise exact product versions, which helps an attacker choose known bugs.

Details

Observed banners: nginx/1.22.1 (main 80/443 and ticket 443), nginx/1.25.5 (main 8080), Apache/2.4.68 (Debian) (blog 80/443 and ticket 8080), PHP/8.2.33 (X-Powered-By on ticket), OpenSSH 9.2p1 Debian 2+deb12u10 on all three IPs, WordPress generator “WordPress 7.1.1”, theme hello-elementor 3.0.0 (WPScan reported latest 3.4.9), osTicket v1.18.4 on the installer page, blog /readme.html and /license.txt reachable. No specific CVE was verified against these versions in this engagement.

Recommendation

Hide Server and X-Powered-By headers. Remove readme.html and license.txt from the web root. Keep WordPress core/themes updated. Avoid displaying product versions on setup pages in production.

5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerabilty assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

A Appendix

A.1 Static Appendix Section

A.2 Remediation priority

Immediate

Finding	Action
Unauthenticated osTicket installer	Take the host offline or finish install privately; restrict or remove `/setup/`; close TCP 8080 if unused

Next

Finding	Action
DOM-based XSS on consultation-success.html	Use textContent instead of innerHTML for the `name` parameter; add a strict Content-Security-Policy
Self-signed TLS and hostname mismatch	Issue a public certificate for ausecurity.best, www.ausecurity.best, and contact.ausecurity.best
Cleartext HTTP on port 8080	Disable port 8080 or bind it to localhost

Planned maintenance

Finding	Action
HTTPS paths redirect to HTTP	Keep trailing-slash redirects on https://
Missing HTTP security headers	Add HSTS (after trusted TLS), CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy
WordPress directory listing	Disable Options Indexes
WordPress XML-RPC	Disable xmlrpc.php if unused
WordPress username admin disclosed	Replace the admin login name; stop author ID redirects
No MX, SPF, or DMARC	Publish mail authentication, or an explicit deny policy if mail is unused
Software version disclosure	Hide Server/X-Powered-By; remove readme.html and license.txt

A.3 Finding severity (from verified CVSS vectors)

Severity labels in this report follow the findings file. CVSS 3.1 vectors were taken from that file and were not guessed.

Title	Severity	CVSS 3.1 vector
Unauthenticated osTicket installer exposed	Critical	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
DOM-based cross-site scripting on consultation success page	Medium	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Self-signed TLS certificate and hostname mismatch on the main site	Medium	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N
Marketing site and ticket installer served over cleartext HTTP on port 8080	Medium	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
HTTPS paths redirect to HTTP	Low	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N
Missing HTTP security headers	Low	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
WordPress directory listing enabled	Low	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
WordPress XML-RPC enabled with pingback and multicall	Low	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L
WordPress administrator username disclosed	Low	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
No MX, SPF, or DMARC for ausecurity.best	Low	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Software version information disclosed	Info	n/a

A.4 Business and contact details

- **Business:** AuSecurity (also seen as Au Security / Ausecurity)
- **Description:** GRC consulting and penetration testing firm
- **Address:** 63 Paddington St, Paddington NSW 2021, Australia
- **Owner:** Vinh Dinh
- **Owner email:** dinh0087@flinders.edu.au
- **Published site email:** info@ausecurity.best
- **Published phone:** +61 2 9000 1234 (may be a placeholder)
- **Website:** https://ausecurity.best/